

Zero Trust: Never Trust, Always Verify

Why zero trust

The perimeter model assumed "inside the firewall = safe." Then breaches showed: 80%+ of intrusions interact with internal systems, and attackers love the un-trusted-inside assumption. Zero trust inverts it: **no implicit trust based on location or network.**

The core principles

Continuous verification – every request authenticated and authorized, regardless of source

Least privilege – minimum access needed, for minimum time

Assume breach – segment, encrypt, monitor as if already compromised

Verify explicitly – identity, device health, context every time

NIST SP 800-207 pillars

All data sources and services are resources

All communication secured regardless of network location

Access granted per-session, not per-network

Access determined by dynamic policy (identity, device, behavior)

Continuous monitoring; no trusted insiders

The ZTNA experience

Instead of a VPN granting the whole network, **Zero Trust Network Access** grants the app:

```
User -> Device check -> Identity (IdP SSO) -> Policy engine
      -> approve/deny -> Micro-segment access to ONE app
```

No lateral movement: even a stolen laptop can reach only approved apps, not the domain controller.

Implementing pragmatically

Identity as the new perimeter (IdP + MFA everywhere)

Micro-segmentation (even in cloud VPCs)

Device compliance checks before resource access

Session logging + behavioral analytics

FIDO2 hardware keys for privileged accounts

The cultural shift

Zero trust is a philosophy, not a product. Vendors sell "ZTNA" but real adoption is policy + telemetry + the willingness to break the "flat network" habit.

[← Defense in Depth: Layers, No...](#)

[Security by Design & Secure De...](#)